

CSI CYBER

ANALISE DINAMICA DE MALWARES



5

LISTA DE FIGURAS

Figura 1 – Página inicial do Any.Run	6
Figura 2 – Página inicial do Hybrid Analysis.....	7
Figura 3 – Página inicial do JOE Sandbox.	8
Figura 4 – Execução do <i>Process Hacker</i>	10
Figura 5 – Tela inicial do <i>Process Hacker</i>	10
Figura 6 – Acessando configuração de cores do <i>Process Hacker</i>	11
Figura 7 – Entendendo de cores do <i>Process Hacker</i>	11
Figura 8 – Incluindo a coluna <i>Verified signer</i> no <i>Process Hacker</i>	12
Figura 9 – Coluna <i>Verified signer</i> do <i>Process Hacker</i>	12
Figura 10 – Verificando a assinatura no <i>Process Hacker</i>	13
Figura 11 – Importando REMnux no Virtualbox.....	14
Figura 12 – Localizando e abrindo arquivo .ovf.....	15
Figura 13 – Localizando arquivo do REMnux.....	15
Figura 14 – Configurando e importando o REMnux	16
Figura 15 – Configurando interface de rede para o REMnux	17
Figura 16 – Configurando interface de rede para o REMnux	17
Figura 17 – Configuração de IP na VM Windows.....	18
Figura 18 – Arquivo de configuração de rede na VM REMnux.....	19
Figura 19 – Alteração na configuração da rede VM REMnux	20
Figura 20 – Configurando inetsim	21
Figura 21 – Arquivo cap04-remnux.exe	22
Figura 22 – Monitoramento do arquivo de log do inetsim.....	22
Figura 23 – Saída do tcpdump.	24

LISTA DE COMANDOS DE PROMPT DO SISTEMA OPERACIONAL

Comando de prompt 1 – Verificando interface no REMnux.	19
Comando de prompt 2 – Aplicando as configurações de rede	20
Comando de prompt 3 – Gerando imphash.	21
Comando de prompt 4 – Gerando imphash	22
Comando de prompt 5 – Saída do tcpdump.....	23

EMANIP

SUMÁRIO

1 ANÁLISE DINÂMICA.....	5
2 ANÁLISE AUTOMATIZADA (SANDBOX)	5
2.1 Análise dinâmica	9
3 PROCESSOS.....	9
3.1 <i>Process Hacker</i>	9
4 ANÁLISE COMPORTAMENTAL	13
CONCLUSÃO.....	24
REFERÊNCIAS.....	25

1 ANÁLISE DINÂMICA

Quando nos vemos num beco sem saída, ou seja, quando a análise estática básica tiver chegado a um ponto em que não conseguimos mais progredir, quer seja por ofuscação, empacotamento, dados estáticos que não geram informação suficiente ou até mesmo quando o analista esgotou todas suas técnicas disponíveis, entramos na análise dinâmica.

Neste capítulo, apresentaremos a análise automatizada e a análise dinâmica ou comportamental de um malware. Iniciaremos com a análise automatizada, na qual conheceremos algumas *sandboxes* disponíveis na internet, será enviado um malware para análise e verificaremos as informações acerca do malware.

Na análise dinâmica, conheceremos alguns softwares para analisar os processos criados após a execução do malware e verificar qual a sua finalidade.

2 ANÁLISE AUTOMATIZADA (SANDBOX)

Na análise automatizada, o malware será executado para que seja possível verificar seu comportamento, porém, não será disponibilizada qualquer interação entre o usuário e o sistema operacional, sendo um grande problema da análise automatizada. Alguns malwares ficam na função *sleep* aguardando que, por exemplo, um usuário execute determinado programa ou acesse algum site específico, como de um banco e, caso essas interações não ocorram, o malware permanecerá estático. Outras desvantagens do uso da análise automatizada são:

- Existe um tempo máximo para a execução do malware, podendo não obter todas as informações comportamentais.
- Apenas executa o arquivo, não podendo passar parâmetros para o malware.
- Caso o malware esteja contido em um arquivo de biblioteca do Windows, .dll, não poderá ser executado.

O objetivo de um ambiente sandbox para engenharia reversa é permitir que você execute um programa de uma maneira que possa observar o comportamento do programa, sem que esse comportamento afete adversamente os componentes críticos de sua plataforma de engenharia reversa. Ambientes de sandbox são comumente construídos usando software

de virtualização, como o VMware ou Virtualbox, mas podem ser construídos em sistemas dedicados que podem ser restaurados a um estado bom conhecido após a execução de qualquer malware. Uma característica comum dos sistemas de área restrita é o fato de que normalmente são fortemente instrumentados para observar e coletar informações sobre o comportamento dos programas executados na área de segurança. Os dados coletados podem incluir informações sobre a atividade do sistema de arquivos de um programa, sobre a atividade de registro de um programa (Windows) e sobre qualquer atividade de rede gerada pelo programa (EAGLE, 2008, tradução minha).

Existem diversas soluções na internet de *sandbox*, algumas gratuitas, outras pagas ou que necessitam de cadastro. Apresentaremos três *sandbox* bastante utilizadas por analistas de malware.



Figura 1 – Página inicial do Any.Run
Fonte: Any Run (2020)

- Prós:
 - Filtro para pesquisa de malwares já analisados e que estejam públicos;
 - Possibilidade de fazer o download do malware;
 - Na versão paga, há a possibilidade de escolher o sistema operacional que será utilizado (Windows Vista, 7, 8.1 e 10);
 - Vídeo da execução fica salvo e disponível publicamente na versão free;
 - Adicionar tempo de execução do malware na versão free, porém, com limites;
 - Possui algumas interações com a VM na versão free.

- Contrás:
 - Necessita de cadastro para uso;
 - Pago para funções mais avançadas.

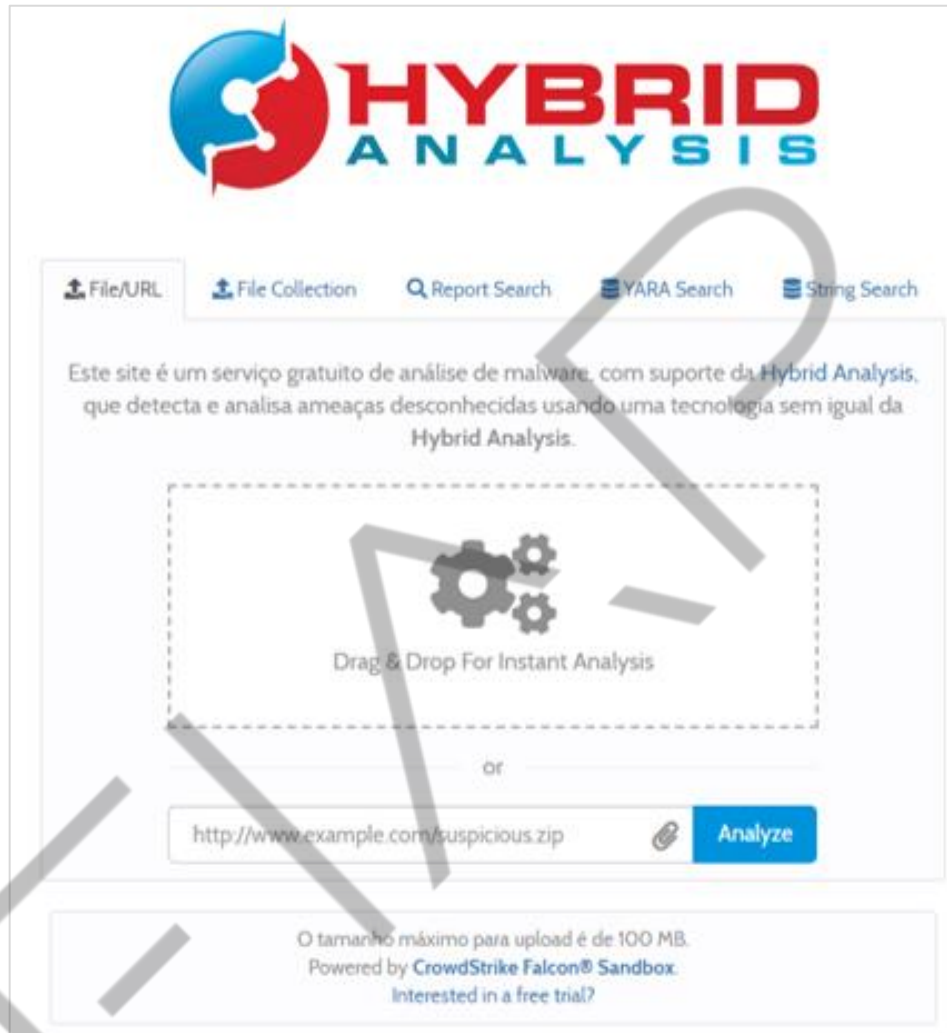


Figura 2 – Página inicial do Hybrid Analysis
Fonte: Hybrid Analysis (2020)

- Prós:
 - Gratuito;
 - Possibilidade de receber um e-mail após a análise do artefato;
 - Escolha entre algumas versões de VMs como Windows 32 ou 64 bits, Android e Linux;
 - Possibilidade de algumas configurações como senha para documentos, variáveis de ambiente, tempo de execução entre outras;
 - Numerosa informação acerca do malware.

- Contrás:
 - Necessita de cadastro para uso de ferramentas avançadas;
 - Processo de verificação para fazer o download do *sample*.

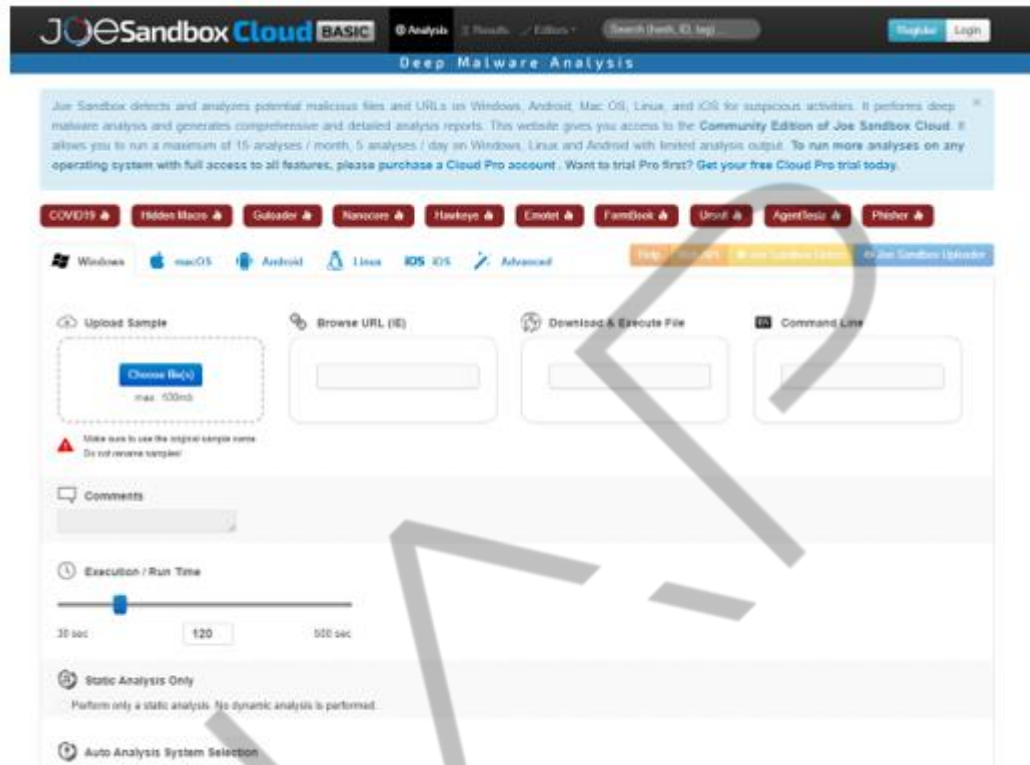


Figura 3 – Página inicial do JOE Sandbox.
Fonte: JOE Sandbox (2020)

- Prós:
 - Gratuito;
 - Possibilidade de receber um e-mail após a análise do artefato;
 - Escolha entre algumas versões de V's como Windows 32 ou 64 bits, Mac OS, Android, iOS e Linux;
 - Possibilidade de algumas configurações como tempo de execução entre outras;
 - Numerosas informações acerca do malware com gráfico do seu comportamento.
- Contrás:
 - Necessita de cadastro para uso de ferramentas avançadas.

2.1 Análise dinâmica

Processo pelo qual analisamos o malware em ambiente totalmente controlado para observar seu comportamento. Muitas informações poderão ser extraídas com essa análise, como, por exemplo, alterações nas chaves de registro, conexões de saída para sites de comando e controle, criação de processos e criação ou deleção de arquivos entre outras.

É por meio da análise dinâmica que podemos identificar, de maneira mais eficiente, a funcionalidade do malware, ou seja, se é um *keylogger*, um *Trojan*, um *ransomware*, um *BOT* etc.

3 PROCESSOS

3.1 Process Hacker

Para analisarmos processos, podemos fazer uso da ferramenta *Process Hacker*. Com uma interface intuitiva, temos acesso direto a todos os processos que estejam sendo executados na máquina.

Download: <<https://processhacker.sourceforge.io/>>.

Conhecendo o *Process Hacker*: Primeiramente, devemos executar o *Process Hacker* com privilégios de administrador:

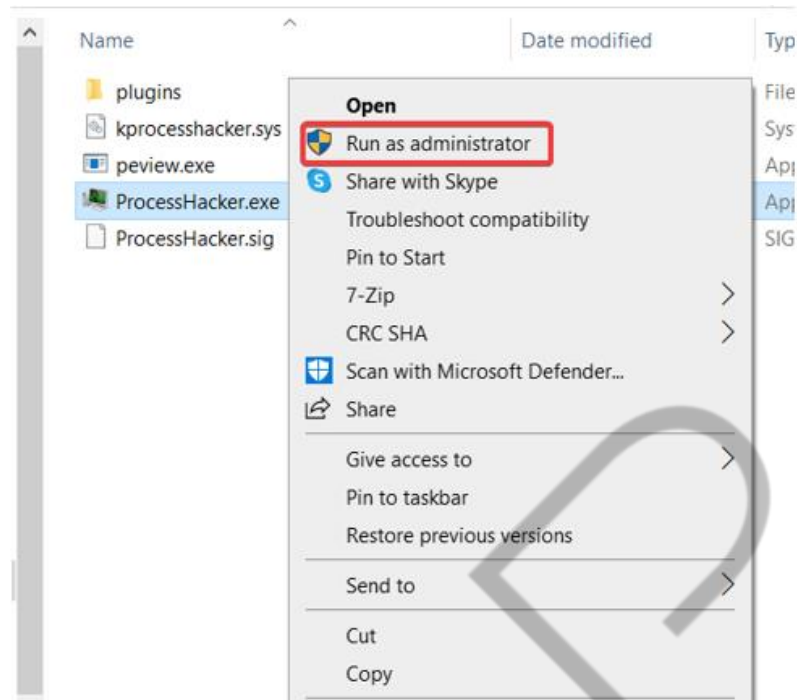


Figura 4 – Execução do *Process Hacker*
Fonte: Elaborado pelo autor (2020)

Assim que executamos o *Process Hacker*, temos a seguinte tela apresentada na Figura “Tela inicial do *Process Hacker*”. Como podemos observar, existem quatro abas interessantes, nas quais podemos descobrir os processos e serviços em execução, tráfego de rede e informações de I/O de disco.

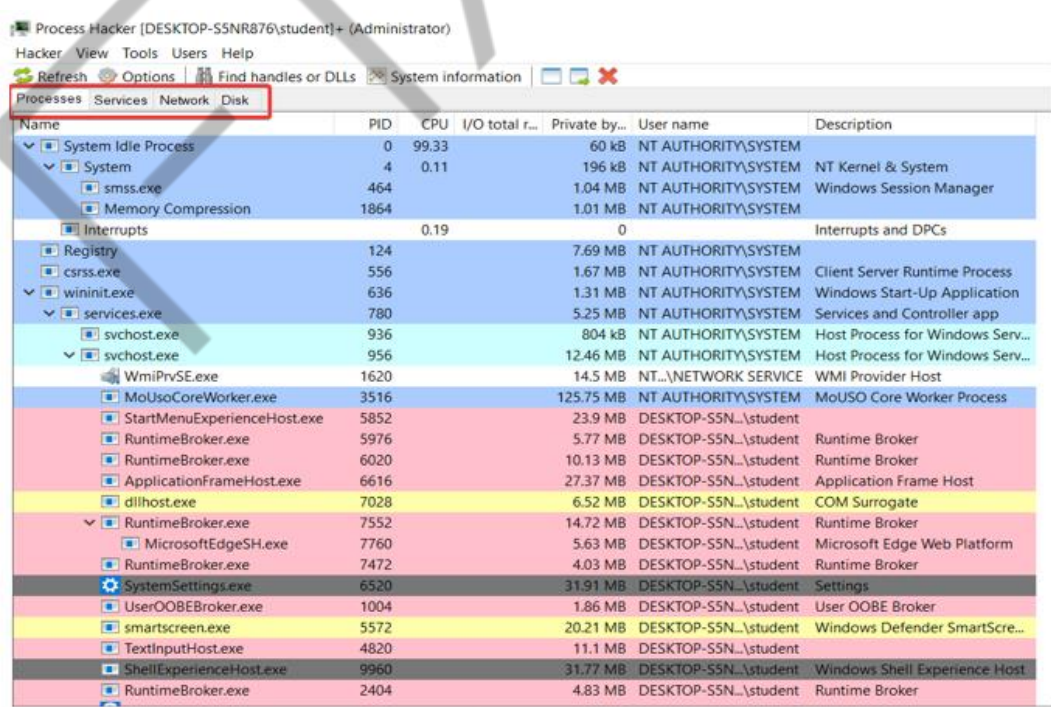


Figura 5 – Tela inicial do *Process Hacker*
Fonte: Elaborado pelo autor (2020)

Para entender as cores de cada processo, podemos abrir as configurações de cores no menu *Hacker* → *Options* e depois acessar a aba *Highlighting*.

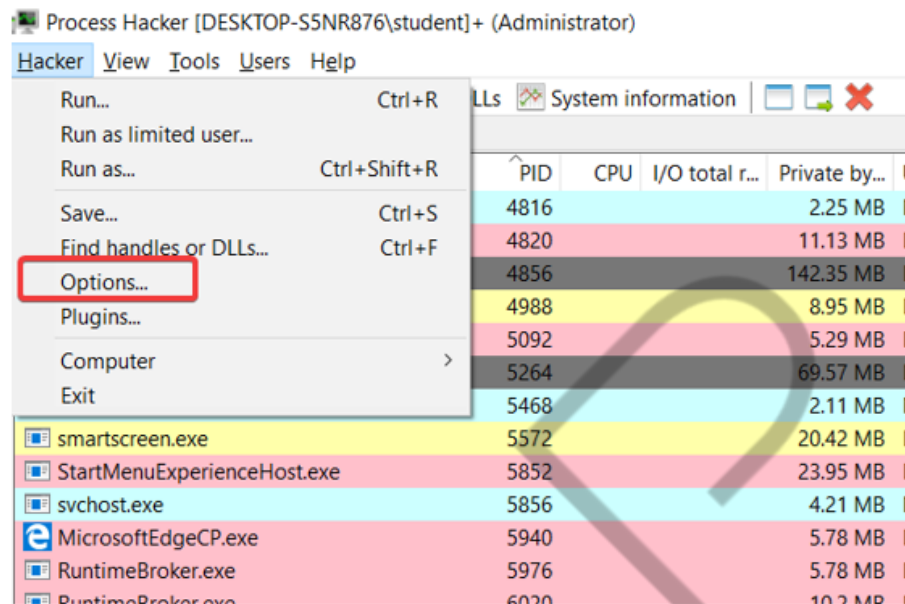


Figura 6 – Acessando configuração de cores do *Process Hacker*
Fonte: Elaborado pelo autor (2020)

Nessa janela é possível, além de identificar qual cor está definida para cada tipo de processo, configurar a cor mais adequada para seu estilo de trabalho.

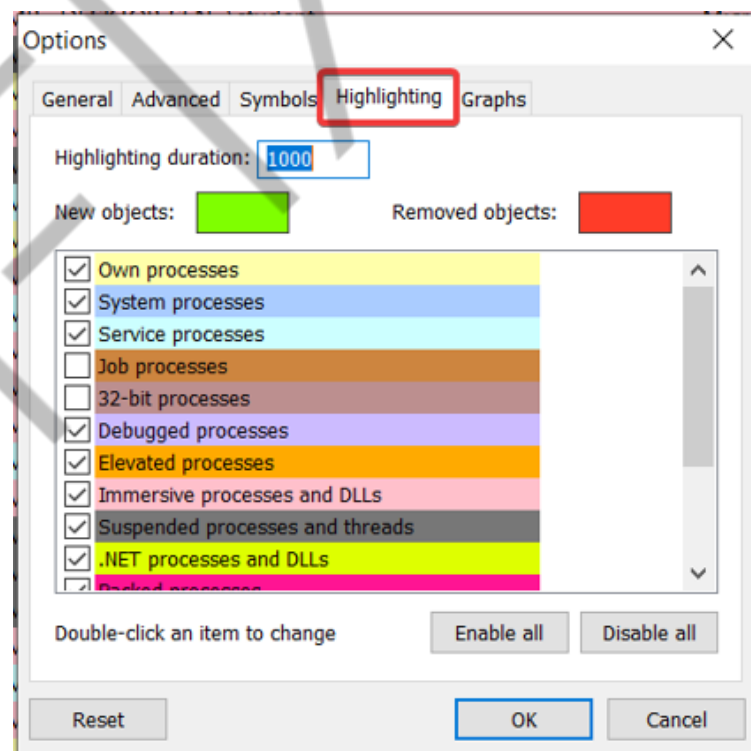


Figura 7 – Entendendo de cores do *Process Hacker*
Fonte: Elaborado pelo autor (2020)

No *Process Hacker*, existe a opção de verificar a assinatura digital da aplicação, porém, essa coluna não vem habilitada por padrão. Clicando com o botão direito sobre qualquer coluna e depois com esquerdo em *Choose Columns*, escolha “Show”.

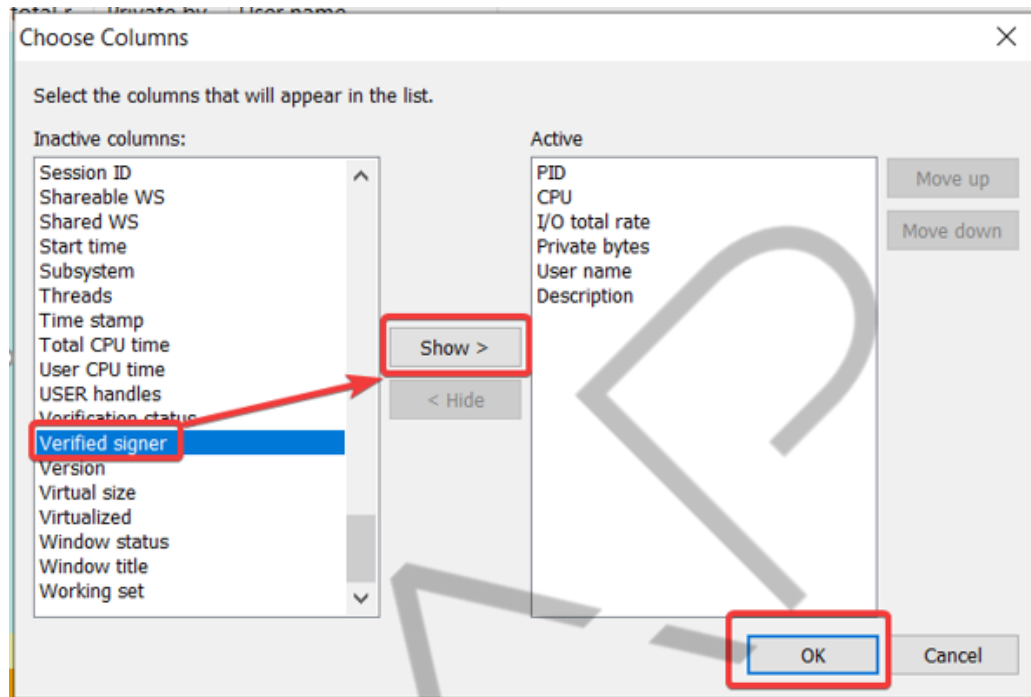


Figura 8 – Incluindo a coluna *Verified signer* no *Process Hacker*

Fonte: Elaborado pelo autor (2020)

Com isso, é fácil verificar rapidamente se o processo está assinado e quem o assina, eliminando algumas variáveis.

Name	PID	CPU	I/O total r...	Private by...	User name	Description	Verified signer
System Idle Process	0	99.02		60 kB	NT AUTHORITY\SYSTEM		
System	4	0.10		196 kB	NT AUTHORITY\SYSTEM	NT Kernel & System	Microsoft Windows
smss.exe	464			1.04 MB	NT AUTHORITY\SYSTEM	Windows Session Manager	Microsoft Windows Publisher
Memory Compression	1864			1.13 MB	NT AUTHORITY\SYSTEM		
Interrupts		0.21		0		Interrupts and DPCs	
Registry	124			5.24 MB	NT AUTHORITY\SYSTEM		
csrss.exe	556			1.72 MB	NT AUTHORITY\SYSTEM	Client Server Runtime Process	Microsoft Windows Publisher
wininit.exe	636			1.31 MB	NT AUTHORITY\SYSTEM	Windows Start-Up Application	Microsoft Windows Publisher
services.exe	780			5.2 MB	NT AUTHORITY\SYSTEM	Services and Controller app	Microsoft Windows Publisher
svchost.exe	936			804 kB	NT AUTHORITY\SYSTEM	Host Process for Windows Serv...	Microsoft Windows Publisher
svchost.exe	956			12.53 MB	NT AUTHORITY\SYSTEM	Host Process for Windows Serv...	Microsoft Windows Publisher
WmiPrvSE.exe	1620			14.4 MB	NT\NETWORK SERVICE	WMI Provider Host	Microsoft Windows
MoUsCoreWorker.exe	3516			125.8 MB	NT AUTHORITY\SYSTEM	MoUSO Core Worker Process	Microsoft Windows
StartMenuExperienceHost.exe	5852			23.61 MB	DESKTOP-SSN...\student		Microsoft Windows
RuntimeBroker.exe	5976			5.79 MB	DESKTOP-SSN...\student	Runtime Broker	Microsoft Windows
RuntimeBroker.exe	6020			10.22 MB	DESKTOP-SSN...\student	Runtime Broker	Microsoft Windows
ApplicationFrameHost.exe	6616			26.24 MB	DESKTOP-SSN...\student	Application Frame Host	Microsoft Windows
dllhost.exe	7028			6.31 MB	DESKTOP-SSN...\student	COM Surrogate	Microsoft Windows
RuntimeBroker.exe	7552			17.59 MB	DESKTOP-SSN...\student	Runtime Broker	Microsoft Windows
MicrosoftEdgeSH.exe	7760			6.36 MB	DESKTOP-SSN...\student	Microsoft Edge Web Platform	Microsoft Windows
RuntimeBroker.exe	7472			4.08 MB	DESKTOP-SSN...\student	Runtime Broker	Microsoft Windows
SystemSettings.exe	6520			31.91 MB	DESKTOP-SSN...\student	Settings	Microsoft Windows
UserOOBEBroker.exe	1004			1.88 MB	DESKTOP-SSN...\student	User OOBE Broker	Microsoft Windows
smartscreen.exe	5572			20.44 MB	DESKTOP-SSN...\student	Windows Defender SmartScre...	Microsoft Windows
TextInputHost.exe	4820			11.14 MB	DESKTOP-SSN...\student		Microsoft Windows
ShellExperienceHost.exe	9960			31.77 MB	DESKTOP-SSN...\student	Windows Shell Experience Host	Microsoft Windows
RuntimeBroker.exe	2404			4.87 MB	DESKTOP-SSN...\student	Runtime Broker	Microsoft Windows
MicrosoftEdge.exe	6420			40 MB	DESKTOP-SSN...\student	Microsoft Edge	Microsoft Corporation

Figura 9 – Coluna *Verified signer* do *Process Hacker*

Fonte: Elaborado pelo autor (2020).

Programas maliciosos não possuem assinatura digital, pois, para que seja gerada, são necessários os dados (identidade, CPF, e-mail, endereço) da pessoa que está gerando a assinatura, desse modo, é inviável para o desenvolvedor de malware criar seu certificado e adicioná-lo a seu malware. Para verificarmos a assinatura de um software, no nosso exemplo, Microsoft Edge, na tela inicial do *Process Hacker*, execute um duplo clique em um dos processos e depois clique em *(Verified) Microsoft Windows*.

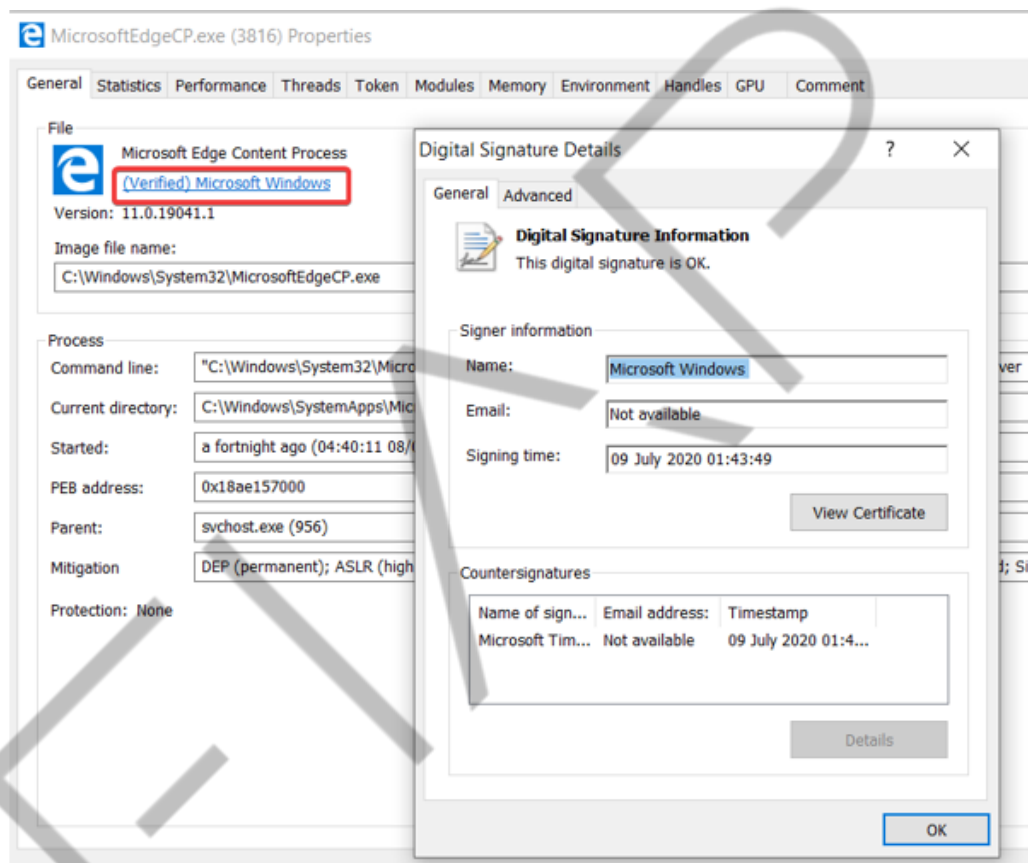


Figura 10 – Verificando a assinatura no *Process Hacker*
Fonte: Elaborado pelo autor (2020)

4 ANÁLISE COMPORTAMENTAL

Para que possamos analisar o comportamento de conexões de um malware na rede não podemos, nem devemos deixar nossa VM exposta à internet, muito menos à nossa rede de produção.

“Ok, Hugo, mas se o malware tentar se conectar a um domínio ou a um IP externo na internet, como resolveremos esse problema?”

Para isso, utilizaremos uma VM chamada REMnux que poderá ser baixada em: <https://docs.remnux.org/install-distro/get-virtual-appliance>.

O REMnux é um conjunto de ferramentas para engenharia reversa, compiladas dentro de uma distribuição Linux e, o melhor, totalmente gratuitas.

Após baixar a imagem disponibilizada no site do projeto, vamos à implantação e configuração dele no Virtualbox.

Primeiro, devemos abrir o arquivo *remnux-v7-virtualbox.ova* no virtual box, seguindo estas etapas: Abrir o Virtualbox e depois clicar em File → Import Appliance ou pressione Ctrl + I:

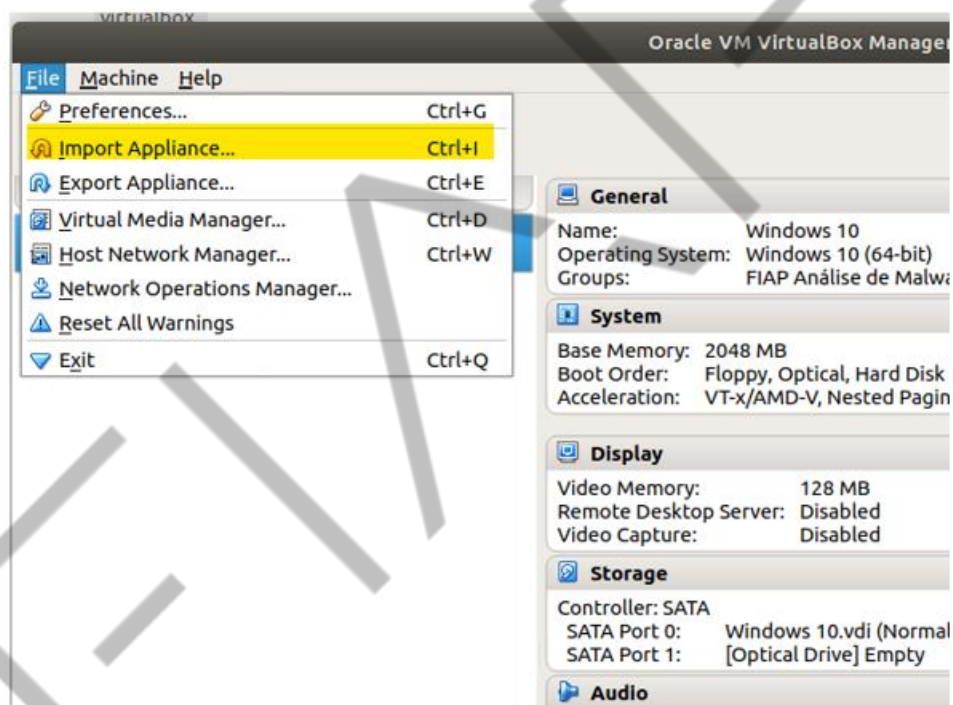


Figura 11 – Importando REMnux no Virtualbox
Fonte: Elaborado pelo autor (2020)

Agora, clicamos no ícone abaixo e navegamos para o local de download do arquivo, no meu caso, em Downloads, selecionamos o arquivo e clicamos em *Open Virtualization Format*.

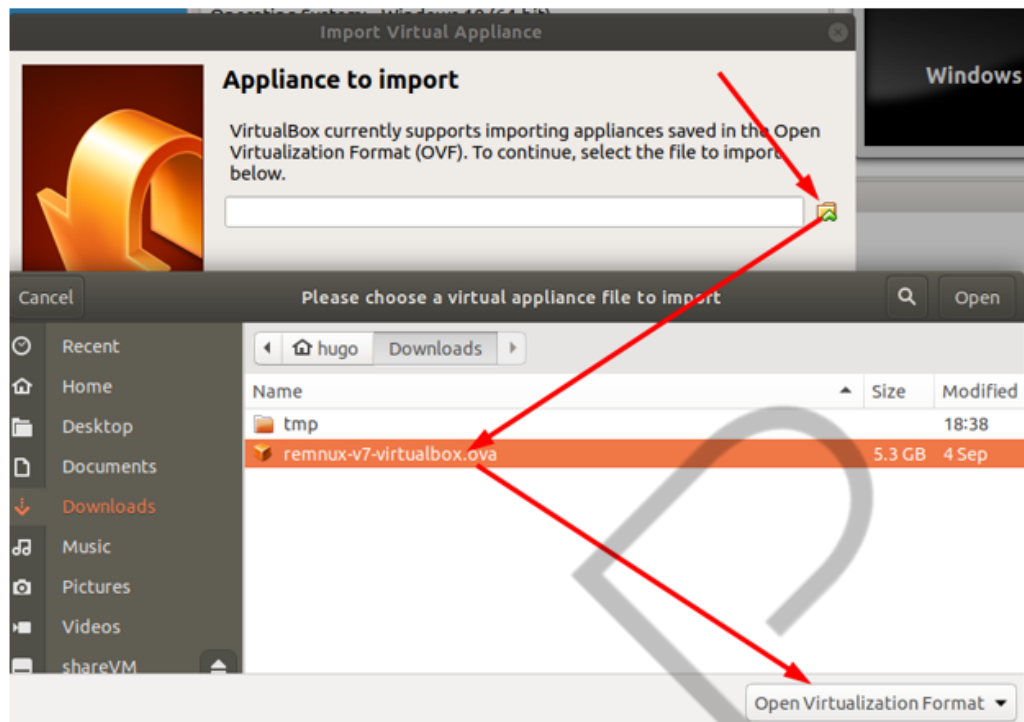


Figura 12 – Localizando e abrindo arquivo .ovf
 Fonte: Elaborado pelo autor (2020)

Agora, clicaremos em *Next* para que possamos configurar esta nova VM no nosso sistema.

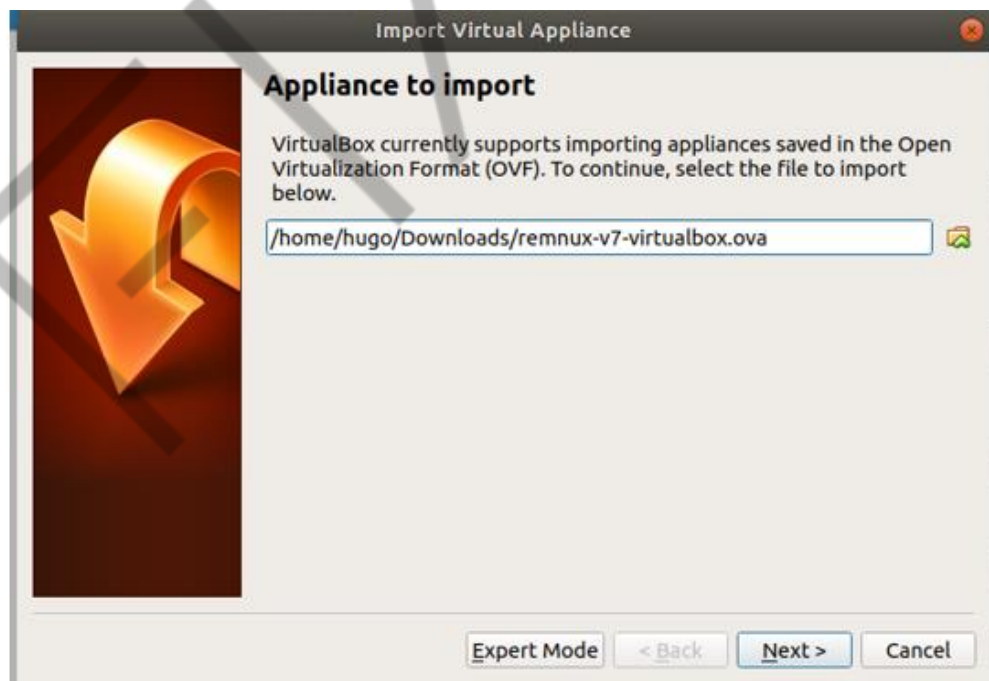


Figura 13 – Localizando arquivo do REMnux
 Fonte: Elaborado pelo autor (2020)

Configure algumas opções em *Appliance settings*, como memória RAM, DVD, Sound Card e USB Controller, pois são coisas que não utilizarei, inicialmente. Caso

precise, no futuro, apenas habilite em *Settings* da VM. Após a configuração, clique em *Import* e aguarde o término do processo.

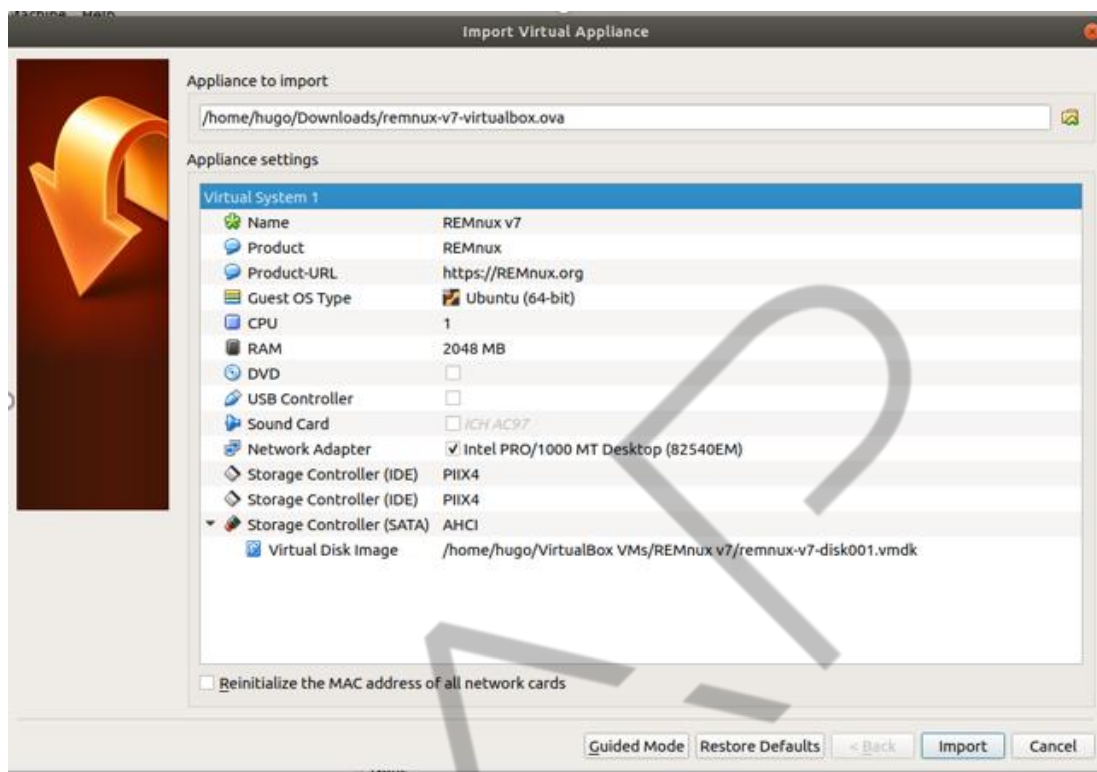


Figura 14 – Configurando e importando o REMnux
Fonte: Elaborado pelo autor (2020)

Ao fim do processo, devemos criar uma rede para que apenas o REMnux e a VM, onde será analisado o malware, estejam presentes. Isso é muito fácil dentro do Virtualbox e existem duas abordagens: utilizar o modo *Host-only Adapter* ou o modo *Internal Network*. Usaremos o *Internal Network* e teremos que adicionar um IP para cada VM que estiver na rede, no nosso caso, o REMnux e o Windows.

Primeiro, clicamos na VM REMnux e depois em *Settings*, procure na coluna lateral esquerda *networking* e, em *Adapter 1*, clique em *Attached* e escolha *Internal Network*, em *Name* altere de "intnet" para "analiseMalware" ou qualquer outro nome de sua escolha.

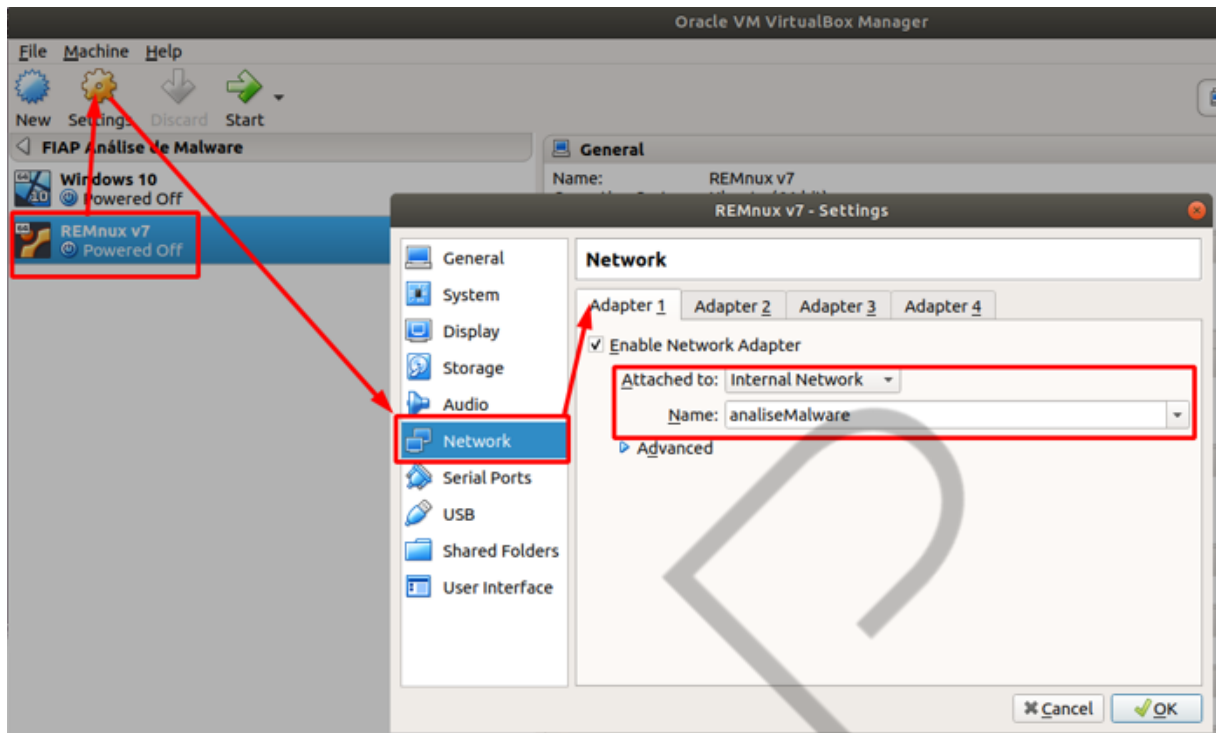


Figura 15 – Configurando interface de rede para o REMnux
Fonte: Elaborado pelo autor (2020)

Agora, siga os mesmos passos para que o Windows esteja na mesma rede interna do REMnux.

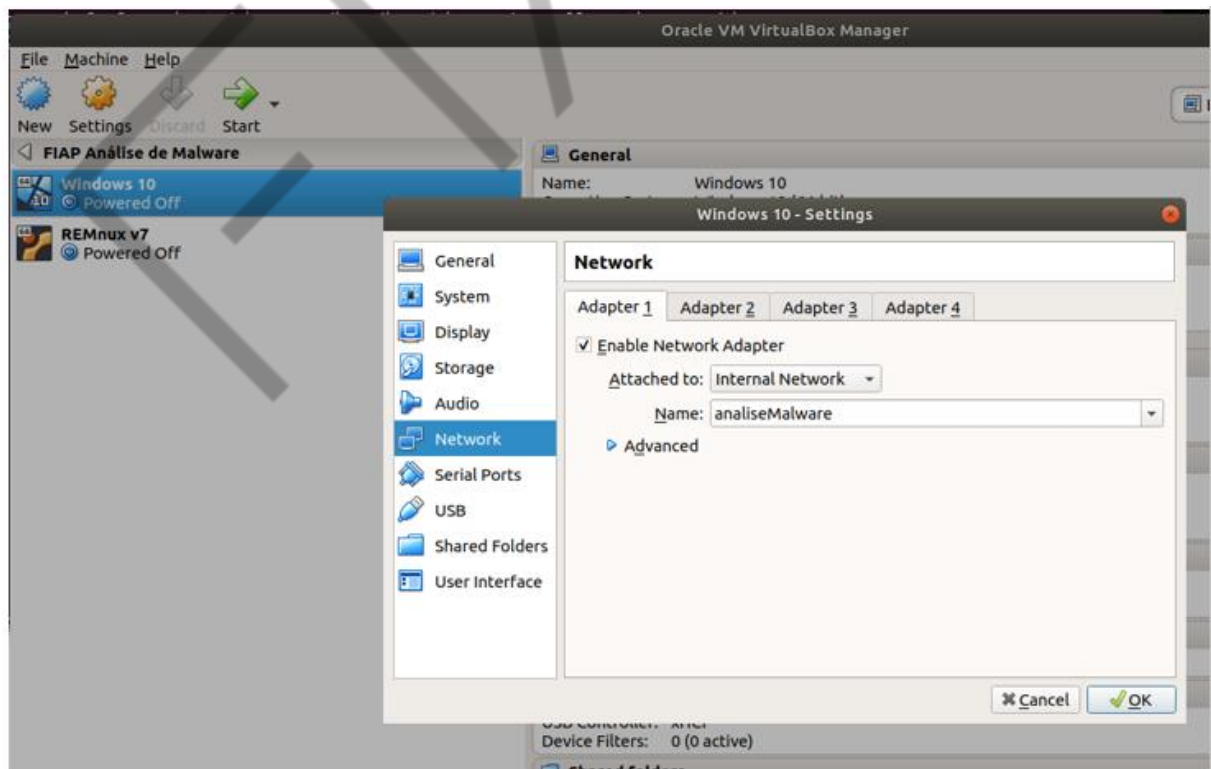


Figura 16 – Configurando interface de rede para o REMnux
Fonte: Elaborado pelo autor (2020)

Vamos iniciar cada VM e inserir um IP e máscara de rede em cada um deles, primeiro, iniciaremos com o REMnux.

No caso do Windows XP configuramos o IP 192.168.26.10 com a máscara 255.255.255.0 ou /24 e o endereço do gateway 192.168.26.1.

Os endereços de gateway e o de DNS (*Domain Name Server*) deverão ser, imprescindivelmente, o IP do REMnux, ou seja, o IP 192.168.26.1 será configurado na interface de rede do REMnux.

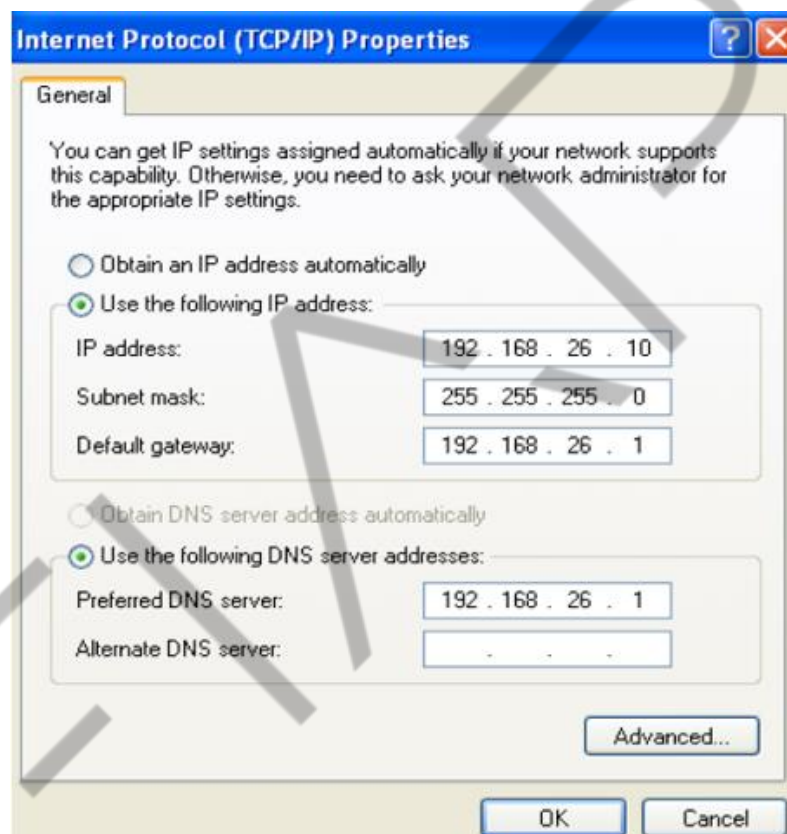


Figura 17 – Configuração de IP na VM Windows
Fonte: Elaborado pelo autor (2020)

Para configuração de IP estático no REMnux precisamos, primeiramente, identificar qual interface queremos configurar. Faremos isso com o comando abaixo:

```
root@remnux:~# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: ens33: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group
default qlen 1000
    link/ether 00:0c:29:7f:19:64 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::20c:29ff:fe7f:1964/64 scope link
        valid_lft forever preferred_lft forever
root@remnux:~#
```

Comando de prompt 1 – Verificando interface no REMnux.
Fonte: Elaborado pelo autor (2020)

Como podemos observar, a interface ens33 não tem IP configurado, para isso, devemos abrir e configurar o arquivo 01-netcfg.yaml que se encontra no diretório /etc/netplan/. A configuração do arquivo se encontra conforme a Figura “Arquivo de configuração de rede na VM REMnux”.

```
# This file describes the network interfaces available on your system
# For more information, see netplan(5).
network:
  version: 2
  renderer: networkd
  ethernets:
    ens33:
      dhcp4: yes
```

Figura 18 – Arquivo de configuração de rede na VM REMnux
Fonte: Elaborado pelo autor (2020)

Devemos alterá-lo para, conforme a Figura “Alteração na configuração da rede VM REMnux”.

```
# This file describes the network interfaces available on your system
# For more information, see netplan(5).
network:
  version: 2
  renderer: networkd
  ethernets:
    ens33:
      dhcp4: no
      addresses: [192.168.26.1/24]
      gateway4: 192.168.26.1
      nameservers:
        addresses: [192.168.1.1]
```

Figura 19 – Alteração na configuração da rede VM REMnux

Fonte: Elaborado pelo autor (2020)

Aplicando as configurações de rede e testando com o comando *ping* para verificar conectividade entre as duas VMs.

```
root@remnux:~# netplan apply
root@remnux:~# ping 192.168.26.10
PING 192.168.26.10 (192.168.26.10) 56(84) bytes of data.
64 bytes from 192.168.26.10: icmp_seq=1 ttl=128 time=0.430 ms
64 bytes from 192.168.26.10: icmp_seq=2 ttl=128 time=0.364 ms
64 bytes from 192.168.26.10: icmp_seq=3 ttl=128 time=0.434 ms
64 bytes from 192.168.26.10: icmp_seq=4 ttl=128 time=0.315 ms
^C
--- 192.168.26.10 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3061ms
rtt min/avg/max/mdev = 0.315/0.385/0.434/0.054 ms
root@remnux:~#
```

Comando de prompt 2 – Aplicando as configurações de rede

Fonte: Elaborado pelo autor (2020)

O software utilizado no REMnux para analisar o comportamento do malware na rede é o *inetsim*:

<https://www.inetsim.org/features.html>.

O *inetsim* é um conjunto de ferramentas que podemos utilizar para criar serviços essenciais para uma análise de malware, com ele podemos simular alguns serviços como http, https, DNS, FTP etc.

Antes de iniciarmos o serviço, precisamos abrir o arquivo de configuração e ativar o serviço de DNS.

O arquivo está localizado em `/etc/inetsim/inetsim.conf` e devemos descomentar a linha `"start_service dns"`, como na Figura "Configurando inetsim".

```
24 # echo_udp, discard_tcp, discard_udp, quotd_tcp,
25 # quotd_udp, chargen_tcp, chargen_udp, finger,
26 # ident, syslog, dummy_tcp, dummy_udp, smtps, pop3s
27 # ftps, irc, https
28 #
29 start_service dns
30 start_service http
31 start_service https
32 start_service smtp
33 start_service smtps
34 start_service pop3
35 start_service pop3s
36 start_service ftp
37 start_service ftps
```

Figura 20 – Configurando inetsim
Fonte: Elaborado pelo autor (2020)

Dica: Para editar o arquivo é necessário estar logado com o usuário root, então execute o comando `"sudo su -"`.

Vamos iniciar a aplicação inetsim, executar o malware no Windows e verificar o arquivo de log do inetsim. Caso o malware tente acessar algum site de internet, o inetsim nos mostrará nesse arquivo.

Para monitorar o arquivo de log utilizaremos um comando do Linux `"tail"` com o parâmetro `-f`, com isso, cada vez que o arquivo for escrito, o `tail -f` apresentará na tela.

```
root@remnux:/etc/inetsim# tail -f /var/log/inetsim/service.log
```

Comando de prompt 3 – Gerando imphash.
Fonte: Elaborado pelo autor (2020)

Como o arquivo encontra-se vazio, nada será apresentado na tela. Agora devemos executar o malware e esperar a conexão do malware ao REMnux.



Figura 21 – Arquivo cap04-remnux.exe
Fonte: Elaborado pelo autor (2020)

Se estiver observando no REMnux, o comando tail nos mostra uma saída, como na Figura “Monitoramento do arquivo de log do inetsim”.

```
root@remnux:/etc/inetsim# tail -f /var/log/inetsim/service.log
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] connect
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] recv: Query Type A, Class IN, Name www.7h15_15_f14p_on_m41w4r3s.com
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] Error: NXDOMAIN
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] disconnect
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] stat: 0 qtype=A qclass=IN qname=www.7h15_15_f14p_on_m41w4r3s.com
```

Figura 22 – Monitoramento do arquivo de log do inetsim
Fonte: Elaborado pelo autor (2020)

```
root@remnux:/etc/inetsim# tail -f /var/log/inetsim/service.log
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] connect
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] recv: Query
Type A, Class IN, Name www.7h15_15_f14p_on_m41w4r3s.com
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] Error:
NXDOMAIN
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] disconnect
[2020-10-17 17:37:22] [31524] [dns_53_tcp_udp 31526] [192.168.26.10] stat: 0
qtype=A qclass=IN qname=www.7h15_15_f14p_on_m41w4r3s.com
```

Comando de prompt 4 – Gerando imphash
Fonte: Elaborado pelo autor (2020)

Outro modo de monitorar as conexões do malware é utilizando a ferramenta tcpdump, com ela é possível, por exemplo, filtrar portas, hosts, ler o conteúdo do protocolo http, chegando ao nível das *flags* do protocolo tcp/ip.

O tcpdump é uma excelente ferramenta para análise de tráfego de rede e, para passar todo seu potencial, seria necessária uma disciplina inteira, então, explicarei brevemente os parâmetros utilizados para o comando abaixo, para mais opções, utilize o manual do tcpdump no Linux (man tcpdump).

- Parâmetros e filtros
 - -n: Não resolve os endereços como hosts e portas para nomes.
 - -i: Configura a interface de rede que você deseja monitorar, no nosso caso, ens33.
 - host: Essa opção é um filtro que utilizamos para dizer ao tcpdump que nos mostre apenas o tráfego destinado ou recebido deste host.
 - -X: Exibe os dados do cabeçalho de cada pacote em Hexadecimal e ASCII.

```
root@remnux:~# tcpdump -ni ens33 host 192.168.26.10 -X
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on ens33, link-type EN10MB (Ethernet), capture size 262144 bytes
06:27:56.319589 ARP, Request who-has 192.168.26.1 tell 192.168.26.10, length 46
  0x0000: 0001 0800 0604 0001 000c 2932 2dd1 c0a8 .....2-...
  0x0010: 1a0a 0000 0000 0000 c0a8 1a01 0000 0000 .....
  0x0020: 0000 0000 0000 0000 0000 0000 0000 0000 .....
06:27:56.319618 ARP, Reply 192.168.26.1 is-at 00:0c:29:7f:19:64, length 28
  0x0000: 0001 0800 0604 0002 000c 297f 1964 c0a8 .....).d..
  0x0010: 1a01 000c 2932 2dd1 c0a8 1a0a .....2-....
06:27:56.319905 IP 192.168.26.10.1077 > 192.168.26.1.53: 55340+ A? www.7h15_15_f14p_on_m41w4r3s.com.
  0x0000: 4500 004e 0295 0000 8011 82ae c0a8 1a0a E..N.....
  0x0010: c0a8 1a01 0435 0035 003a d9b6 d82c 0100 .....5.5:....,..
  0x0020: 0001 0000 0000 0000 0377 7777 1837 6831 .....www.7h1
  0x0030: 355f 3135 5f66 3134 705f 6f6e 5f6d 3431 5_15_f14p_on_m41
  0x0040: 7734 7233 7303 636f 6d00 0001 0001 w4r3s.com.....
06:27:56.328321 IP 192.168.26.1.53 > 192.168.26.10.1077: 55340 NXDomain*- 0/0/0 (50)
  0x0000: 4500 004e e984 4000 4011 9bbe c0a8 1a01 E..N..@.@.....
  0x0010: c0a8 1a0a 0035 0435 003a b5a7 d82c 8503 .....5.5:....,..
  0x0020: 0001 0000 0000 0000 0377 7777 1837 6831 .....www.7h1
  0x0030: 355f 3135 5f66 3134 705f 6f6e 5f6d 3431 5_15_f14p_on_m41
  0x0040: 7734 7233 7303 636f 6d00 0001 0001 w4r3s.com.....
```

Comando de prompt 5 – Saída do tcpdump.
Fonte: Elaborado pelo autor (2020)


```

tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on ens33, link-type EN10MB (Ethernet), capture size 262144 bytes
06:27:56.319589 ARP, Request who-has 192.168.26.1 tell 192.168.26.10, length 46
  0x0000: 0001 0800 0604 0001 000c 2932 2dd1 c0a8 .....2-...
  0x0010: 1a0a 0000 0000 0000 c0a8 1a01 0000 0000 .....
  0x0020: 0000 0000 0000 0000 0000 0000 0000 .....
06:27:56.319618 ARP, Reply 192.168.26.1 is-at 00:0c:29:7f:19:64, length 28
  0x0000: 0001 0800 0604 0002 000c 297f 1964 c0a8 .....).d..
  0x0010: 1a01 000c 2932 2dd1 c0a8 1a0a .....2-....
06:27:56.319905 IP 192.168.26.10.1077 > 192.168.26.1.53: 55340+ A? www.7h15_15_f14p_on_m4lw4r3s.com.
  0x0000: 4500 004e 0295 0000 8011 82ae c0a8 1a0a E..N.....
  0x0010: c0a8 1a01 0435 0035 003a d9b6 d82c 0100 .....5.5:.....
  0x0020: 0001 0000 0000 0000 0377 7777 1837 6831 .....www.7h1
  0x0030: 355f 3135 5f66 3134 705f 6f6e 5f6d 3431 5_15_f14p_on_m4l
  0x0040: 7734 7233 7303 636f 6d00 0001 0001 w4r3s.com.....
06:27:56.328321 IP 192.168.26.1.53 > 192.168.26.10.1077: 55340 NXDomain*- 0/0/0 (50)
  0x0000: 4500 004e e984 4000 4011 9bbe c0a8 1a01 E..N..@.....
  0x0010: c0a8 1a0a 0035 0435 003a b5a7 d82c 8503 .....5.5:.....
  0x0020: 0001 0000 0000 0000 0377 7777 1837 6831 .....www.7h1
  0x0030: 355f 3135 5f66 3134 705f 6f6e 5f6d 3431 5_15_f14p_on_m4l
  0x0040: 7734 7233 7303 636f 6d00 0001 0001 w4r3s.com.....

```

Figura 23 – Saída do tcpdump.
Fonte: Elaborado pelo autor (2020)

CONCLUSÃO

A análise dinâmica, diferentemente da análise estática, é de extrema importância para um analista de malware. A partir dela, por vezes, ocorre a forma como realmente conseguimos encontrar a verdadeira finalidade do malware.

Vimos que existem vários sites externos, nos quais podemos analisar o comportamento de um malware de forma totalmente automatizada e que nos trazem um relatório quase pronto, porém podemos nos deparar com arquivos .dll que, por exemplo, em algumas *sandboxes*, não será possível analisá-lo.

Em contrapartida, na análise comportamental, temos todo o controle do nosso ambiente e podemos analisar por partes a execução do malware, caso ele precise de servidor FTP para salvar um arquivo ou um servidor HTTP para buscar um arquivo, podemos simular tudo isso com o REMnux.

REFERÊNCIAS

EAGLE, C. **The IDA Pro book: the unofficial guide to the world's most popular disassembler**. San Francisco, CA: No Starch Press, 2008.

EMANIP